



ACTIONS ON CYBER

— PRACTICAL GUIDANCE. REAL PROTECTION. —
READY TODAY. SECURE TOMORROW.

NIST CSF ALIGNED CYBER RISK MANAGEMENT POLICY

NIST CSF Alignment: Govern | Identify

Defines how cyber risks are identified, assessed, treated, accepted, monitored and reported.

Document type: Policy template | Version: 1.0

Audience: Small and medium-sized organisations

Review frequency: Annual, or after a material incident, audit finding or major change

ACTIONS ON CYBER

Practical Guidance. Real Protection. Ready Today. Secure Tomorrow.

Cyber Risk Management Policy

Template status: standalone starter policy for the Actions on Cyber Field Manual.

Disclaimer

This template is a starting point only. It is not legal advice and should be adapted to the organisation, sector, operating model, risk appetite, contractual duties and regulatory obligations.

Document control

Field	Suggested wording
Policy owner	[Insert role, for example Managing Director, Operations Director, Head of IT, Risk Owner or Cyber Lead]
Approved by	[Insert approving body, for example Board, Trustees or Senior Leadership Team]
Version	1.0
Effective date	[Insert date]
Next review date	[Insert date]
NIST CSF alignment	Govern and Identify - risk management strategy, risk identification, risk assessment, risk treatment and oversight

Contents

- 1. Purpose
- 2. Scope
- 3. Risk management principles
- 4. NIST CSF alignment
- 5. Policy statements
- 6. Roles and responsibilities
- 7. Risk scoring method
- 8. Risk treatment and acceptance
- 9. Risk register and reporting
- 10. Review and continual improvement
- Appendix A. Cyber risk register fields
- Appendix B. Risk acceptance record

1. Purpose

The purpose of this policy is to define how cyber security risks are identified, assessed, prioritised, treated, accepted, monitored and reported across the organisation. It ensures cyber risk is visible, owned and managed as a business risk rather than only a technical issue.

This policy provides a practical risk management baseline for small and medium-sized organisations. It should be used with a cyber risk register, risk scoring matrix, risk acceptance process, supplier security reviews, incident response plan and relevant security control policies.

2. Scope

This policy applies to all business systems, information assets, cloud services, suppliers, devices, networks, users, data and business processes that could affect the confidentiality, integrity or availability of organisational information or services.

It applies to employees, contractors, temporary workers, suppliers and any other party who has access to organisational systems, data or services.

3. Risk management principles

- Cyber risks should be described in business language, including the event, cause and potential impact.
- Every material cyber risk should have a named owner who is accountable for treatment and review.
- Risk assessment should consider likelihood, impact, existing controls, data sensitivity, supplier dependency and business disruption.
- Treatment decisions should be proportionate to the size of the organisation, the value of the asset and the level of potential harm.
- Accepted risks and policy exceptions should be documented, approved, time-limited and reviewed before expiry.
- Risk records should be updated using lessons from incidents, audits, vulnerability findings, supplier reviews and business changes.

4. NIST CSF alignment

This policy is primarily aligned to the NIST Cybersecurity Framework functions of Govern and Identify. It also supports Protect, Detect, Respond and Recover by ensuring risks, control gaps and improvement actions are visible and owned.

NIST CSF Function	How this policy supports it
Govern	Defines risk ownership, appetite, decision-making, reporting, acceptance, escalation and oversight.
Identify	Supports identification and assessment of risks affecting assets, data, suppliers, systems and business services.
Protect	Connects risk treatment to protective controls such as MFA, patching, backups, data handling and supplier access.
Detect	Uses findings from monitoring, vulnerabilities, audits and control testing to identify and update cyber risks.
Respond	Uses incidents and near misses to update risks, assign actions and prioritise corrective activity.
Recover	Uses recovery lessons and business continuity gaps to improve resilience and reduce future risk.

5. Policy statements

The following policy statements define the minimum cyber risk management expectations for the organisation.

- The organisation must maintain a cyber risk register for material risks affecting systems, data, suppliers or business services.
- Each cyber risk must have a named risk owner and, where appropriate, a separate action owner for remediation activity.
- Cyber risks must be assessed using a consistent likelihood and impact scoring method.
- Risk ratings must consider operational, financial, legal, regulatory, customer and reputational impact.
- Each risk must have a treatment decision: reduce, avoid, transfer or accept.
- High and critical risks must be escalated to senior leadership for visibility and decision-making.
- Accepted risks must be documented, approved by an appropriate senior owner, time-limited and reviewed before expiry.
- Material technology, supplier, data, AI or process changes must include cyber risk consideration before implementation.
- Incidents, near misses, audit findings and control failures must be reviewed to identify new risks or update existing risks.
- Cyber risk management arrangements must be reviewed at least annually and after significant incidents or business changes.

6. Roles and responsibilities

Role	Responsibilities
Board, trustees or owners	Approve the cyber risk management approach, set risk appetite, review material risks and support priority remediation decisions.
Senior accountable owner	Own the cyber risk management process, approve priorities, escalate material issues and confirm risk acceptance decisions.
Policy owner	Maintain this policy, coordinate reviews and ensure the risk process remains practical and fit for purpose.
Risk owners	Own specific cyber risks, agree treatment actions, monitor progress and escalate issues when required.
Cyber/security lead or IT lead	Support risk identification, technical assessment, control design, remediation planning and reporting.
System, data and supplier owners	Understand risks affecting their systems, data or suppliers and ensure agreed controls are implemented.
All users	Report suspicious activity, incidents, weaknesses, policy breaches and changes that may create cyber risk.

7. Risk scoring method

Cyber risks should be assessed using likelihood and impact. The overall rating should guide prioritisation, reporting and treatment urgency. The example below can be adapted to suit the organisation.

Score	Likelihood	Impact
1 - Low	Unlikely to occur, or would require unusual circumstances.	Limited disruption, low sensitivity data, minor financial or reputational impact.
2 - Medium	Could occur, based on known threats, weaknesses or past experience.	Noticeable disruption, moderate data exposure, customer concern or management attention required.
3 - High	Likely to occur, an active weakness exists, or the threat is credible and relevant.	Major service disruption, sensitive data exposure, significant financial loss, legal or regulatory concern, or serious reputational harm.

Overall rating

Overall risk rating should be calculated using likelihood x impact. Example: 1-2 Low, 3-4 Medium, 6 High and 9 Critical. The organisation may adjust scoring thresholds to match its own risk appetite.

8. Risk treatment and acceptance

Each cyber risk must have a treatment decision. The decision should be recorded in the risk register with an owner, due date, status and evidence requirement.

Treatment option	Description	Example
Reduce / mitigate	Implement controls to reduce likelihood or impact.	Enable MFA, patch a critical vulnerability, improve backups or restrict admin access.
Avoid	Stop the activity that creates the risk.	Do not onboard a supplier that cannot meet minimum security expectations.
Transfer	Transfer part of the risk contractually or financially while retaining accountability.	Use cyber insurance or contractual indemnities where appropriate.
Accept	Accept the risk where it is within appetite and approved by an appropriate senior owner.	Approve a time-bound exception where remediation is not immediately feasible.

9. Risk register and reporting

The cyber risk register should be maintained as a live management record. It should support clear decisions, not become an administrative exercise. At a minimum, senior management should receive visibility of the highest rated risks, overdue actions, accepted risks and decisions required.

Report item	Minimum expectation
Top risks	Summarise critical and high risks, business impact, treatment progress and decisions required.
Overdue actions	Highlight actions that are past due and need support, funding, resource or reprioritisation.
Accepted risks	List accepted risks, approval dates, expiry dates, compensating controls and approvers.
Emerging risks	Identify new risks from threats, suppliers, technology changes, AI use, incidents or regulatory change.
Control weaknesses	Summarise gaps in important controls such as MFA, backups, patching, logging, access reviews or supplier assurance.

Suggested review frequency

Item	Suggested frequency
Critical risks	Weekly or until stabilised.
High risks	Monthly.
Medium risks	Quarterly.
Low risks	Every six to twelve months.
Risk appetite	Annually or after a major change.
This policy	Annually or after a material incident, audit finding, regulatory change or business change.

10. Review and continual improvement

This policy should be reviewed at least annually and after any significant security incident, audit finding, major supplier change, technology change, business change or change in legal or regulatory expectations.

Improvement actions should be tracked to completion. Lessons from incidents, tabletop exercises, vulnerability findings, supplier reviews, audits and control testing should be used to update risk records and control priorities.

Appendix A. Cyber risk register fields

The cyber risk register should include, as a minimum, the following fields.

Field	Purpose
Risk ID	Unique reference number, for example CYB-001.
Risk title	Short description of the risk.
Risk description	What could happen, why it could happen and what the impact could be.
Business impact	Operational, financial, legal, regulatory, customer or reputational impact.
NIST CSF function	Govern, Identify, Protect, Detect, Respond or Recover.
Existing controls	Controls already in place.
Likelihood / impact / rating	Consistent risk score and priority.
Risk owner	Named accountable owner.
Treatment decision	Reduce, avoid, transfer or accept.
Actions, owner and due date	Agreed remediation activity with accountable action owner.
Status and review date	Open, in progress, accepted, closed, plus next review date.

Appendix B. Risk acceptance record

Use this record when a risk will not be remediated immediately or where the organisation decides to accept the residual risk.

Field	Detail
Risk ID	[Insert risk ID]
Risk title	[Insert risk title]
Reason for acceptance	[Explain why the risk is being accepted]
Current rating	[Low / Medium / High / Critical]
Compensating controls	[List temporary or alternative controls]
Acceptance expiry date	[Insert date]
Approver	[Insert senior owner]
Review requirements	[Define review frequency and conditions]

Document end

Tailor this policy before use. Replace bracketed fields, align risk ownership to your operating model and link this policy to your cyber risk register, governance policy, incident response plan and supplier security process.